BUSINESS REQUIREMENTS DOCUMENT

PROJECT NAME: Aetheris HealthLink Integration Platform

COMPANY NAME: Aetheris Medical Systems

VERSION: 1.0.0

DATE: October 24, 2023

VERSION HISTORY

VERSION	APPROVED BY	REVISION DATE	DESCRIPTION OF CHANGE	AUTHOR
1.0.0	Dr. Aris Thorne	10/24/2023	Initial Draft for Executive Review	Sarah Jenkins

1. EXECUTIVE SUMMARY SNAPSHOT

Aetheris HealthLink is a high-priority, cloud-native infrastructure initiative designed to solve the systemic fragmentation of patient data across regional and national healthcare providers. In the current medical landscape, clinical workflows are severely compromised by "data silos," where vital patient records exist in isolation within specific hospital networks or private clinics. Internal research suggests that clinicians spend upwards of 30% of their daily operational bandwidth manually requesting, chasing, and verifying records from external systems—a process that is not only financially wasteful but also prone to fatal errors due to incomplete information.

Our data analysis indicates that implementing a centralized, high-availability interoperability layer can reduce diagnostic delays by 45%, prevent up to 15% of duplicate diagnostic testing (saving millions in unnecessary procedures), and significantly reduce provider burnout by streamlining administrative tasks. This document outlines the comprehensive requirements for a platform facilitating real-time, bidirectional FHIR (Fast Healthcare Interoperability Resources) data exchange.

The project scope encompasses the engineering of a core high-concurrency API gateway, a secure, HIPAA-compliant clinician portal, and a "security-first" architecture that treats data integrity as a clinical outcome. The primary business drivers include the drastic reduction of operational overhead, the mitigation of medical-legal risks associated with "missing data," and the attainment of elite security certifications. By tripling our integration footprint across North America, Aetheris aims to establish the definitive gold standard for secure, low-latency medical data transit, ultimately democratizing access to clinical history and improving patient outcomes at a continental scale.

2. PROJECT DESCRIPTION

The primary goal of the HealthLink project is to bridge the massive technological and administrative gap between disparate Electronic Health Record (EHR) systems such as Epic, Cerner, Meditech, and Allscripts.

- **Current Process:** Healthcare providers currently rely on antiquated legacy methods such as physical faxing, unencrypted email attachments, or siloed manual portal uploads. These methods are non-searchable, non-structured, and require manual data re-entry into the destination EHR. This "manual bridge" introduces human-error risks, such as transcription errors that can lead to incorrect dosing or missed allergy warnings.
- **Challenges:** Existing interoperability solutions are often "all-or-nothing," lacking the granular **Authorization** controls required for modern privacy. This often results in a clinician being granted broad access to a patient's entire multi-decade medical history—including sensitive behavioral health, genetic data, or reproductive history—when they only required a specific electrolyte panel result. This "over-provisioning" violates the "principle of least privilege" and creates massive compliance liabilities for all participating entities.
- **The Solution:** There is an urgent need for an automated, intelligent system that utilizes advanced identity matching to link records across institutions. The system must ensure every user identity is rigorously verified through modern, multi-layered **Authentication** protocols while maintaining a performant, "frictionless" user experience for busy medical staff. HealthLink will serve as the digital connective tissue for a unified healthcare ecosystem.

3. PROJECT SCOPE

IN SCOPE

- **High-Performance API Gateway:** Development of a FHIR R4-compliant API capable of handling 10,000+ concurrent requests per second. This includes rate-limiting, request validation, and schema transformation for real-time data ingestion.
- **Enterprise Master Patient Index (EMPI):** Implementation of an EMPI using sophisticated probabilistic matching algorithms (utilizing traits like partial names, DOB, address history, and SSN fragments) to ensure "Patient A" in a rural clinic is correctly mapped to "Patient A" in a metropolitan trauma center.
- **Security & Session Management:** Deployment of a unified **Session Management** layer. This allows a clinician to move between different departmental applications (e.g., Cardiology to Radiology) within the HealthLink portal without needing to re-authenticate, while ensuring the underlying token remains secure and short-lived.
- **Automated Maintenance Infrastructure:** Implementation of **Application Patching** pipelines utilizing blue-green deployment strategies. This ensures that security vulnerabilities in the underlying libraries or OS are patched within 24 hours without ever taking the critical healthcare service offline.
- **Clinician Dashboard:** A responsive, "read-only" web interface optimized for both desktop and tablet use, allowing physicians to view aggregated data outside of their primary EHR

when necessary (e.g., during emergency transport).

OUT OF SCOPE

- **Direct Database Writes:** We will not directly alter or "push" data into third-party EHR database schemas; we will interact strictly through their certified API or HL7 interface layers to maintain data integrity.
- **Physical Infrastructure:** Physical server procurement and data center management are excluded. All infrastructure is managed as code (IaC) via AWS.
- **Patient-Facing Mobile App:** While patient access is a roadmap goal for 2025, this phase focuses exclusively on Provider-to-Provider (P2P) data exchange.
- **Data Cleansing:** The project does not include the manual "scrubbing" or correction of existing corrupt data within the source systems (e.g., fixing a 10-year-old typo in a legacy clinic's database).

4. BUSINESS DRIVERS

- **Operational Efficiency & Cost Reduction:** Every manual fax request costs a hospital approximately $12 in labor. Automating this reconciliation across thousands of encounters saves millions in administrative overhead annually.
- **Regulatory Compliance & Federal Mandates:** Explicit alignment with the "No Surprises Act" and CMS Interoperability rules. Compliance is no longer optional; failure to provide data portabilty results in significant federal penalties and loss of CMS reimbursement eligibility.
- **Cyber Resilience & Risk Mitigation:** Implementing stringent **System Hardening** is a prerequisite for operating in an era where healthcare ransomware attacks have increased by 200%. Protecting the integrity of medical data is treated as a core patient safety issue.
- **Strategic Market Positioning:** Obtaining **Certification & Compliance** credentials (SOC2 Type II, HITRUST, HIPAA) creates a high barrier to entry for smaller competitors and is a non-negotiable requirement for securing contracts with state-level Health Information Exchanges (HIEs).

5. CURRENT PROCESS: A CLINICAL SCENARIO

Consider a specialist in an oncology clinic who needs the latest PET scan results for a patient whose scan was performed at a specialized imaging center in another state.

1. **Identification:** The oncology nurse spends 15 minutes identifying which imaging center holds the records.
2. **Request:** The nurse calls the center, waits on hold, and is told to fax a "Release of Information" (ROI) form.
3. **Transmission:** The ROI is faxed; the imaging center faxes back a 45-page report.
4. **Data Entry:** A medical assistant receives the blurry fax, scans it as a low-quality PDF into the oncology EHR, and manually types the summary into the patient's chart.

5. **Review:** The oncologist reviews the data. Because the fax was blurry, a critical measurement of a tumor is misread, leading to a potential sub-optimal treatment plan.

Security Gap: This manual process completely lacks a centralized **Logging & Monitoring** system. If a clerk views a celebrity's medical records out of curiosity, there is no digital trail or alert, leading to "ghost" HIPAA violations that often go undetected for years.

6. PROPOSED PROCESS: THE HEALTHLINK WORKFLOW

1. **SSO Handshake:** The clinician logs into their hospital's EHR. HealthLink's background service recognizes the session via SSO and carries over the verified identity.
2. **Silent Query:** As the clinician opens the chart for "John Doe," HealthLink's API gateway queries the regional network for any records associated with John Doe's EMPI profile.
3. **Structured View:** Within seconds, a "Longitudinal Record" appears, showing labs from Clinic A, imaging from Center B, and meds from Pharmacy C, all formatted in a clean, standardized view.
4. **Automated Audit:** Every "view" event is captured in an immutable, encrypted log. Compliance officers can see exactly which clinician viewed which data point and for how long.
5. **Anomaly Detection:** The **Logging & Monitoring** system uses AI to detect if a user's behavior changes—for example, if a physician who usually views 10 records a day suddenly attempts to export 500 records, the session is instantly suspended and an alert is sent to the Security Operations Center (SOC).

7. FUNCTIONAL REQUIREMENTS

PRIORITY TABLE

VALUE	RATING	DESCRIPTION
1	Critical	Essential for project success; the project is legally or technically impossible without it.
2	High	Important for MVP launch, but could be deferred by 30 days if absolutely necessary.
3	Medium	Provides high value to clinicians but is not a "blocker" for the initial rollout.
4	Low	"Nice to have" UI enhancements or secondary reporting features.
5	Future	Roadmap items for subsequent fiscal years (e.g., AI-driven predictive diagnostics).

REQUIREMENTS CATEGORIES (RC1)

ID	REQUIREMENT	PRIORITY	RAISED BY

FR-01	**Authorization Logic:** Implement Attribute-Based Access Control (ABAC). Access must be determined by user role, patient consent status, and clinical location. Roles are synced with LDAP/Active Directory; access reviews must be performed and logged every 30 days.	1	Chief Security Officer
FR-02	**Authentication Protocols:** Mandatory FIDO2-compliant MFA for all human users. For machine-to-machine traffic, service accounts must use short-lived (60-minute) rotating certificates managed via a secure vault, strictly forbidding static API keys.	1	Engineering Lead
FR-03	**Consent Management:** The system must verify the patient's "Opt-In" status for data sharing at every request. If a patient revokes consent, their data must be immediately "ghosted" from the network view.	1	Legal Counsel
FR-04	**Emergency "Break-Glass":** In life-threatening scenarios (ER/Trauma), clinicians may override standard ABAC restrictions to view vitals. This action must trigger a high-priority "Audit Event" that requires manual sign-off by a supervisor within 24 hours.	2	Chief Medical Officer
FR-05	**Data Normalization Engine:** Automatically map legacy HL7 v2 code sets (e.g., proprietary lab codes) to standard LOINC or SNOMED CT codes before presenting them in the FHIR JSON output.	1	Integration Lead

8. NON-FUNCTIONAL REQUIREMENTS

ID	REQUIREMENT	CATEGORY
NFR-01	**Logging & Monitoring:** Log every successful/failed login, data query, and system config change. Logs must be stored in WORM (Write Once, Read Many) storage for a minimum of 7 years. Real-time dashboards must track "Mean Time to Detection" (MTTD) for anomalies.	Operations
NFR-02	**Certification & Compliance:** The entire platform must pass annual HITRUST CSF and SOC2 Type II audits. Automated compliance "Guardrails" must run every 4 hours to ensure that any unauthorized configuration changes are automatically reverted.	Governance
NFR-03	**Application Patching:** All high/critical CVEs must be patched within 24 hours. The CI/CD pipeline must support "Canary Releases," where patches are rolled out to a small subset of non-critical clinics first to verify stability.	Operations
NFR-04	**System Hardening:** All cloud nodes must be hardened to CIS Level 2 Benchmarks. The network architecture must use "Zero Trust" micro-segmentation, ensuring that a compromise of the Web Portal does not allow lateral movement to the Database layer.	Security
NFR-05	**Session Management:** Sessions must expire after 15 minutes of inactivity. Session tokens (JWTs) must be stored in HttpOnly, Secure, and SameSite=Strict cookies to prevent cross-site scripting (XSS) and session hijacking.	Security

NFR-06	**Scalability & Performance:** The API must return results for a patient query in under 500ms, even during peak loads of 5,000 requests per second. The system must auto-scale across multiple AWS availability zones.	Performance

9. FINANCIAL STATEMENTS

The initial development and security hardening of HealthLink represent a significant capital expenditure. However, we project that the automation of record retrieval will save hospital partners an average of $45 per patient encounter in labor and "lost time" costs. Furthermore, by achieving HITRUST certification, the company qualifies for a 25% reduction in annual cyber-liability insurance premiums.

We anticipate a total Phase 1 investment of $3.2M. Based on current pilot performance, the system is projected to reach break-even within 18 months, yielding a cumulative 350% ROI by the end of year three. Detailed quarterly projections and cloud cost-optimization strategies are available in the Supplemental Financial Analysis document.

10. COST AND BENEFIT

- **Tangible Costs:**
  - **Cloud Infrastructure:** $15k/mo for a high-availability, multi-region AWS environment (RDS, EKS, CloudTrail).
  - **Third-party Compliance:** $50k/annually for independent penetration testing and SOC2/HITRUST auditing fees.
  - **Expert Personnel:** $120k/mo for a specialized team of senior backend, security, and DevOps engineers.
- **Intangible Costs:**
  - **Training Burden:** Initial "friction" as clinical staff transition away from familiar legacy faxing workflows.
- **Tangible Benefits:**
  - **Labor Savings:** Estimated $2.1M/year in saved administrative labor for a typical 500-bed hospital network.
  - **Diagnostic Speed:** 50% reduction in "Time-to-Diagnosis" for patients transferred into Emergency Departments without existing records.
- **Intangible Benefits:**
  - **Clinician Wellness:** Significant reduction in "click fatigue" and administrative frustration.
  - **Public Trust:** Enhanced reputation as a provider that treats patient data privacy as a sacred trust.

11. RESOURCES

- **Personnel Requirements:**
  - **4 Senior Backend Engineers:** Specialists in Go or Rust for high-concurrency API development.
  - **2 Cloud Security Architects:** Must hold CISSP or AWS Security Specialty certifications.
  - **1 Compliance Officer:** Deep expertise in HIPAA, HITECH, and HITRUST frameworks.
  - **1 Clinical Workflow Expert:** A former nurse or physician to ensure the UI matches real-world medical needs.
- **Technical Stack:**
  - **Infrastructure:** AWS (Amazon EKS for container orchestration, RDS for managed databases, Lambda for serverless tasks).
  - **Identity & Security:** Okta for **Authentication**, HashiCorp Vault for secret management, and Auth0 for external partner bridging.
  - **Observability:** Datadog for **Logging & Monitoring**, Snyk for automated code-vulnerability scanning.
  - **Automation:** Terraform (IaC) and GitHub Actions to manage the **Application Patching** lifecycle.

12. SCHEDULE, TIMELINE, AND DEADLINES

- **Month 1-2 (Foundation):** Setup AWS Landing Zone. Finalize FHIR R4 data schemas. Implement core **Authentication** and **Authorization** (ABAC) modules.
- **Month 3-4 (Integration):** Deploy the EMPI matching engine. Start the first phase of "Alpha" testing with 2 regional clinics.
- **Month 5 (Hardening):** Full **System Hardening** according to CIS benchmarks. Internal "Red Team" penetration testing to identify and fix vulnerabilities.
- **Month 6 (Compliance):** Submission for HITRUST **Certification**. Finalize documentation for SOC2 Type II.
- **Month 7 (Scaling):** "Beta" rollout to 5 additional hospitals. Performance tuning for high-concurrency loads.
- **Month 8 (Launch):** Full production "Go-Live" across the initial 15-site regional network.

13. ASSUMPTIONS

- **Hospital IT Cooperation:** We assume that participating hospital IT departments will whitelist HealthLink IP ranges and grant necessary firewall exceptions for HL7/FHIR traffic.
- **Regulatory Stability:** We assume the core tenets of the 21st Century Cures Act will remain stable through the 2024-2025 development cycle.
- **Library Support:** We assume that third-party library maintainers (e.g., for FHIR parsing) will provide timely security updates to support our strict **Application Patching**

requirements.

- **Data Availability:** We assume that at least 90% of legacy clinics can provide an HL7 v2.3 or higher data feed.

14. GLOSSARY

TERM	EXPLANATION
FHIR R4	Fast Healthcare Interoperability Resources (v4) - The modern JSON-based standard for health data exchange.
ABAC	Attribute-Based Access Control - An authorization model that considers the user, the resource, and the context (e.g., time of day).
EMPI	Enterprise Master Patient Index - A tool used to uniquely identify patients across multiple healthcare systems.
CIS Benchmarks	Industry-standard configuration guidelines for hardening operating systems and cloud services.
WORM Storage	Write Once, Read Many - A data storage technology that prevents data from being erased or altered after it is written.
LOINC / SNOMED	International standard vocabularies for identifying medical laboratory observations and clinical terms.

15. REFERENCES

- **HIPAA Security Rule Overview:** hhs.gov/hipaa/security
- **NIST Cybersecurity Framework (CSF):** nist.gov/cyberframework
- **CMS Interoperability Rule (9115-F):** cms.gov/interoperability
- **AWS Security Best Practices:** aws.amazon.com/security

16. APPENDIX

- **Appendix A:** Technical Flowcharts showing HL7-to-FHIR transformation logic and EMPI matching weights.
- **Appendix B:** Full RBAC/ABAC Permissions Matrix (Defining what an "On-Call Surgeon" can see vs. a "Billing Clerk").
- **Appendix C: System Hardening** Checklist specifically for Kubernetes (EKS) Worker